安全杂项讲解与实践

Yasar、Nano

2024-07-01

《中华人民共和国刑法》

第二百八十五条

【非法侵入计算机信息系统罪】

- 违反国家规定，侵入国家事务、国防建设、尖端科学技术领域的计算机信息系统的，处三年以下有期徒刑或者拘役。

【非法获取计算机信息系统数据、非法控制计算机信息系统罪】

- 违反国家规定，侵入前款规定以外的计算机信息系统或者采用其他技术手段，获取该计算机信息系统中存储、处理或者传输的数据，或者对该计算机信息系统实施非法控制，情节严重的，处三年以下有期徒刑或者拘役，并处或者单处罚金；情节特别严重的，处三年以上七年以下有期徒刑，并处罚金。

【提供侵入、非法控制计算机信息系统程序、工具罪】

- 提供专门用于侵入、非法控制计算机信息系统的程序、工具，或者明知他人实施侵入、非法控制计算机信息系统的违法犯罪行为而为其提供程序、工具，情节严重的，依照前款的规定处罚。

单位犯前三款罪的，对单位判处罚金，并对其直接负责的主管人员和其他直接责任人员，依照各该款的规定处罚。

《中华人民共和国刑法》

第二百八十六条

【破坏计算机信息系统罪】

- 违反国家规定，对计算机信息系统功能进行删除、修改、增加、干扰，造成计算机信息系统不能正常运行，后果严重的，处五年以下有期徒刑或者拘役；后果特别严重的，处五年以上有期徒刑。
- 违反国家规定，对计算机信息系统中存储、处理或者传输的数据和应用程序进行删除、修改、增加的操作，后果严重的，依照前款的规定处罚。
- 故意制作、传播计算机病毒等破坏性程序，影响计算机系统正常运行，后果严重的，依照第一款的规定处罚。

单位犯前三款罪的，对单位判处罚金，并对其直接负责的主管人员和其他直接责任人员，依照第一款的规定处罚。

《中华人民共和国网络安全法》

第二十七条

任何个人和组织不得从事非法侵入他人网络、干扰他人网络正常功能、窃取网络数据等危害网络安全的活动;不得提供专门用于从事侵入网络、干扰网络正常功能及防护措施、窃取网络数据等危害网络安全活动的程序、工具；明知他人从事危害网络安全的活动的，不得为其提供技术支持、广告推广、支付结算等帮助。

第四十四条

任何个人和组织不得窃取或者以其他非法方式获取个人信息，不得非法出售或者非法向他人提供个人信息。

《中华人民共和国网络安全法》

第六十三条

- 违反本法第二十七条规定，从事危害网络安全的活动，或者提供专门用于从事危害网络安全活动的程序、工具，或者为他人从事危害网络安全的活动提供技术支持、广告推广、支付结算等帮助，尚不构成犯罪的，由公安机关没收违法所得，处五日以下拘留，可以并处五万元以上五十万元以下罚款;情节较重的，处五日以上十五日以下拘留，可以并处十万元以上一百万元以下罚款。
- 单位有前款行为的，由公安机关没收违法所得，处十万元以上一百万元以下罚款，并对直接负责的主管人员和其他直接责任人员依照前款规定处罚。
- 违反本法第二十七条规定，受到治安管理处罚的人员，五年内不得从事网络安全管理和网络运营关键岗位的工作;受到刑事处罚的人员，终身不得从事网络安全管理和网络运营关键岗位的工作。

第六十四条

违反本法第四十四条规定，窃取或者以其他非法方式获取、非法出售或者非法向他人提供个人信息，尚不构成犯罪的，由公安机关没收违法所得，并处违法所得一倍以上十倍以下罚款，没有违法所得的，处一百万元以下罚款。

PuzzleGames

必须搞一点有趣的事情

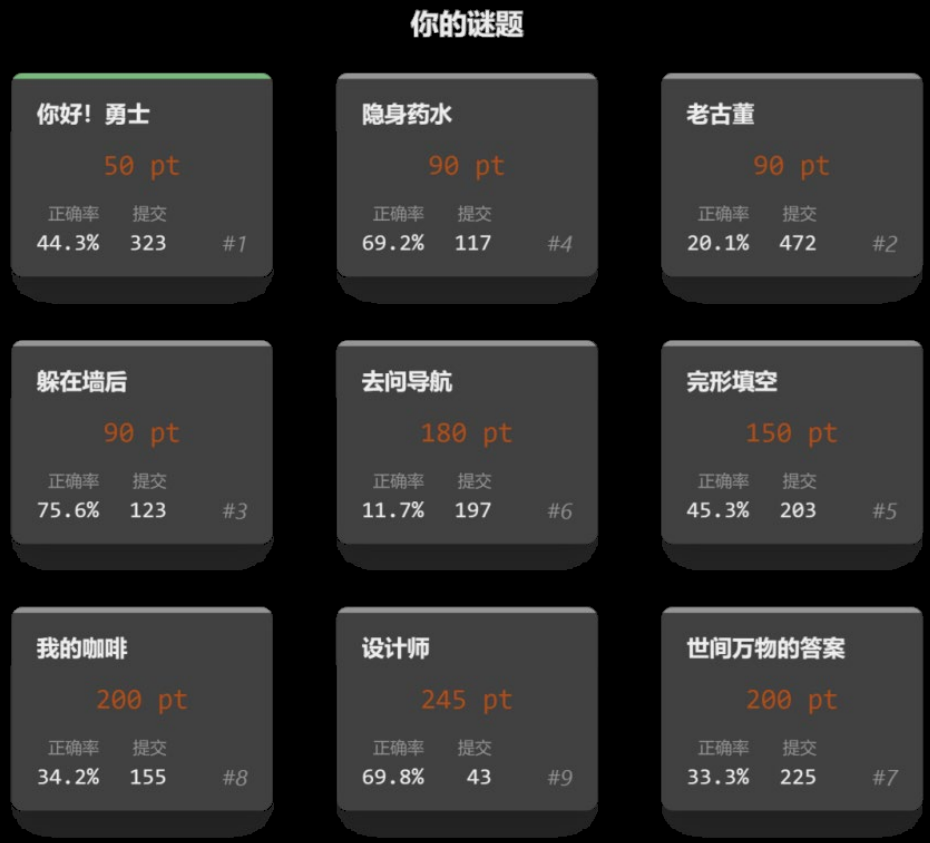
PuzzleGames

- MSC 解谜: https://sysums.club/puzzle



PuzzleGames

- MSC 解谜 v2: https://puzzle.sysums.club



PuzzleGames

- GZTime PGv1: https://puzzle.gztime.cc



PuzzleGames

- Nazo Game: https://nazo.one-story.cn/

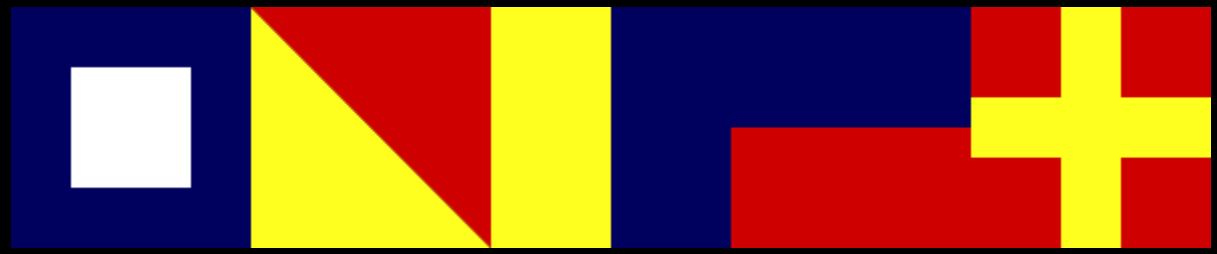


PuzzleGames

- Nazo Game: https://nazo.one-story.cn/
  - A、H、I、M、?、?、?、V、W、X、Y
    - **OTU**
  - 5B88 671B 5148 950B
    - **守望先锋**
  - 9

    16 ? 18

    35
    - **Chlorine**
  - 见右图
    - **poker**



PuzzleGames

- 古典密码：凯撒密码，猪圈密码，维吉尼亚密码……
- 信息编码：Base64，ASCII，UTF-8，盲文，二维码，条形码……
- 加密解密：RC4，RSA，AES，ECC……
- 信息隐写：LSB（最低有效位）隐写，图种……
- 谜题游戏：Nonograms，Word Cross……
- 工具使用：Google，Bing，Binwalk……
- 信息搜集：地图识别，照片中的线索……
- 各种奇奇怪怪的其他知识……

PuzzleGames



「1024×768 大小的图片，可以轻松藏下 786432 个地址。」

R,G,B,A => xxx.xxx.xxx.xxx

CTFMisc

必须搞一点有趣的事情

CTFMisc

$ nc ctf.yasar.li 65100
web > http://ctf.yasar.li:65199/wnc/65100
http://ctf.yasar.li:65199/string_tool.zip

string_tool

Nano 同学的字符串工具

Nano 同学最近刚刚学会了 Python 的字符串操作，于是写了两个小程序运行在自己的服务器上。

这个工具提供两个功能：

字符串大写工具以及 UTF-7 到 UTF-8 转换工具

CTFMisc - string_tool

$ nc ctf.yasar.li 65100

```
def to_upper(s):
    r = re.compile('[fF][lL][aA][gG]')
    if r.match(s):
        print('how dare you')
    elif s.upper() == 'FLAG':
        print('yes, I will give you the flag')
        print(open('flag1').read())
    else:
        print('%s' % s.upper())
```

CTFMisc - string_tool

$ nc ctf.yasar.li 65100

```
def to_utf8(s):
    r = re.compile('[fF][lL][aA][gG]')
    s = s.encode() # make it bytes
    if r.match(s.decode()):
        print('how dare you')
    elif s.decode('utf-7') == 'flag':
        print('yes, I will give you the flag')
        print(open('flag2').read())
    else:
        print('%s' % s.decode('utf-7'))
```

CTFMisc - string_tool

- Task 1: flag

```
for i in range(0, 65535):
    if chr(i).upper() == 'FL' or chr(i).upper() == 'LA'
or chr(i).upper() == 'AG':
        print(chr(i))
        break
```

- Task 2: +AGYAbABhAGc

CTFMisc

$ nc ctf.yasar.li 65101
web > http://ctf.yasar.li:65199/wnc/65101
http://ctf.yasar.li:65199/unboxing_simulator.zip

unboxing_simulator

开箱模拟器

想体验开箱的快乐吗?

这是一个开箱模拟器。当你输入「BF 开箱码」之后，程序会模拟 128 轮游戏，每轮你有 64 次开箱机会。

如果你 128 轮中每轮都能够在 64 次机会之内找到目标所在的箱子，那么你将会得到 flag。

CTFMisc - unboxing_simulator

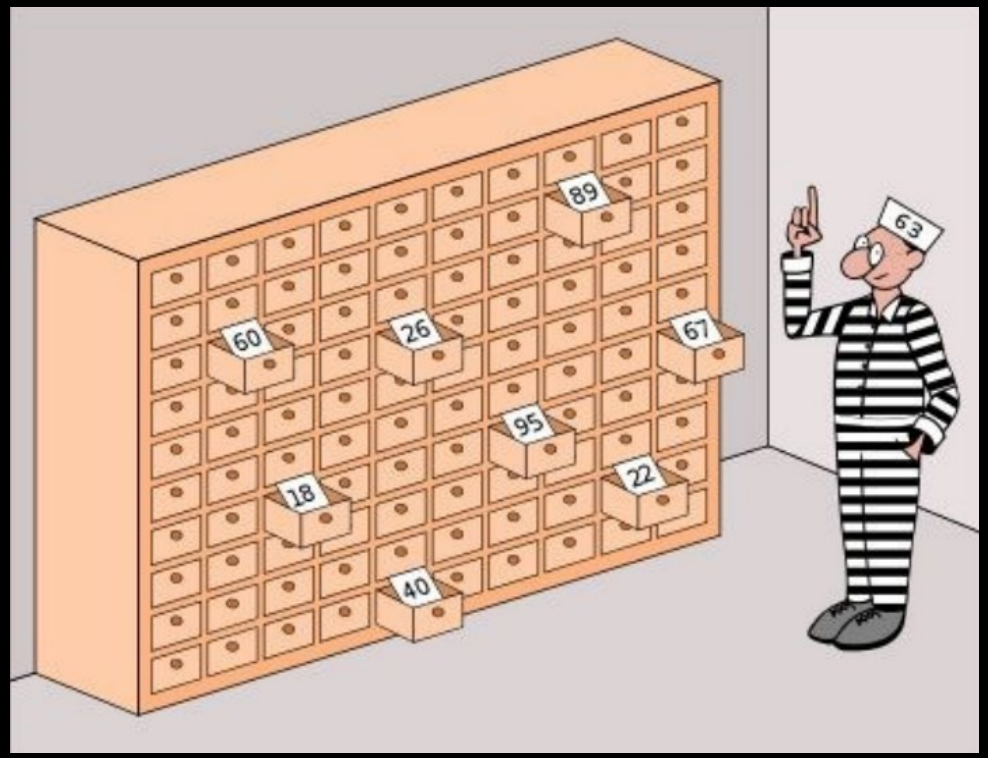
$ nc ctf.yasar.li 65101

- Brainfuck: https://minond.xyz/brainfuck/

brainfuck command	C equivalent
(Program Start)	char array[BIG_NUM] = {0}; char *ptr = array;
>	++ptr;
<	--ptr;
+	++*ptr;
-	--*ptr;
.	putchar(*ptr);
,	*ptr = getchar();
[	while (*ptr) {
]	}

CTFMisc - unboxing_simulator

$ nc ctf.yasar.li 65101



百囚徒问题变种

- 所有囚徒能够通过挑战，当且仅当所有圆环的长度不超过 64

CTFMisc - unboxing_simulator

$ nc ctf.yasar.li 65101

Have a Try

,>++<[-[>.>+<<-]>+.-->[<.>-]<+<,]

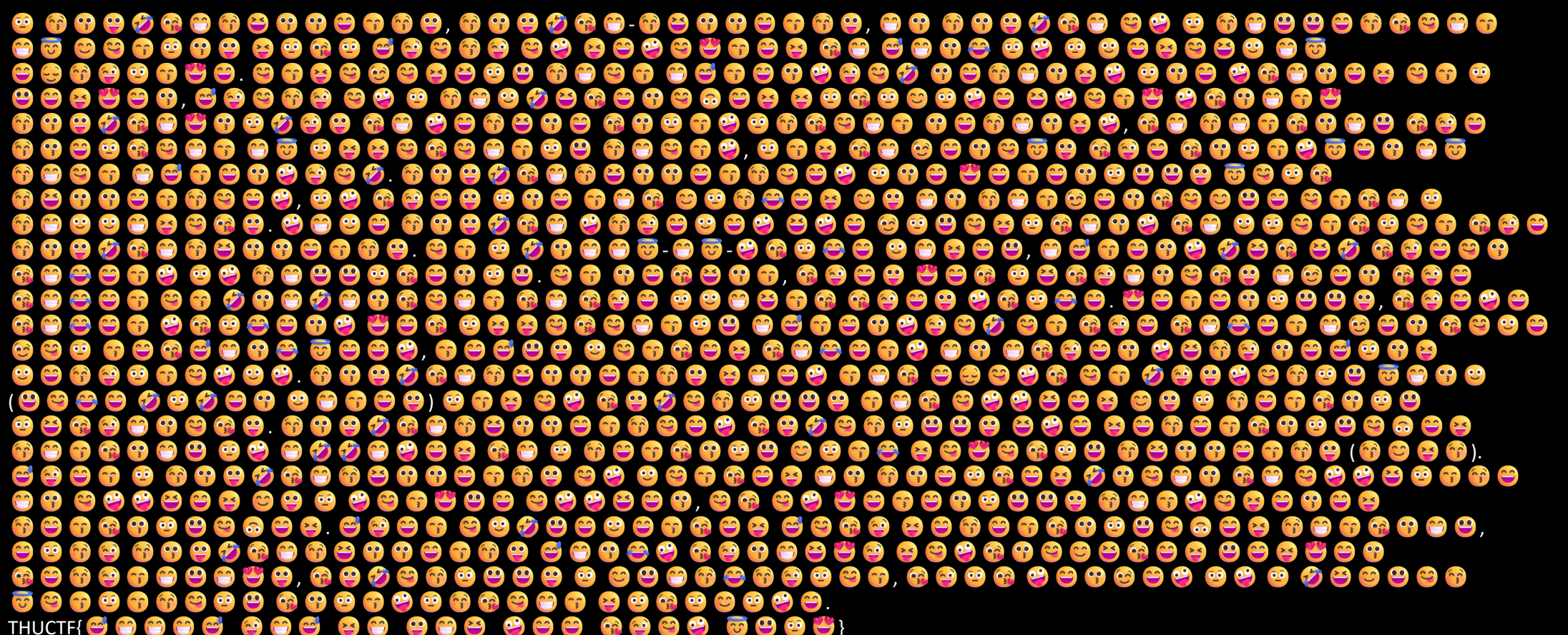
CTFMisc

http://ctf.yasar.li:65199/emojicorrre.zip

emojicorrre

😉😄😗😘😊

CTFMisc - emojicorrre



CTFMisc - emojicorrre

- 单表替换密码： https://quipqiup.com/



CTFMisc

http://ctf.yasar.li:65199/broken_qrcode.zip

broken_qrcode

被破坏的二维码

有一个二维码被破坏了，你能帮忙读取内容吗？

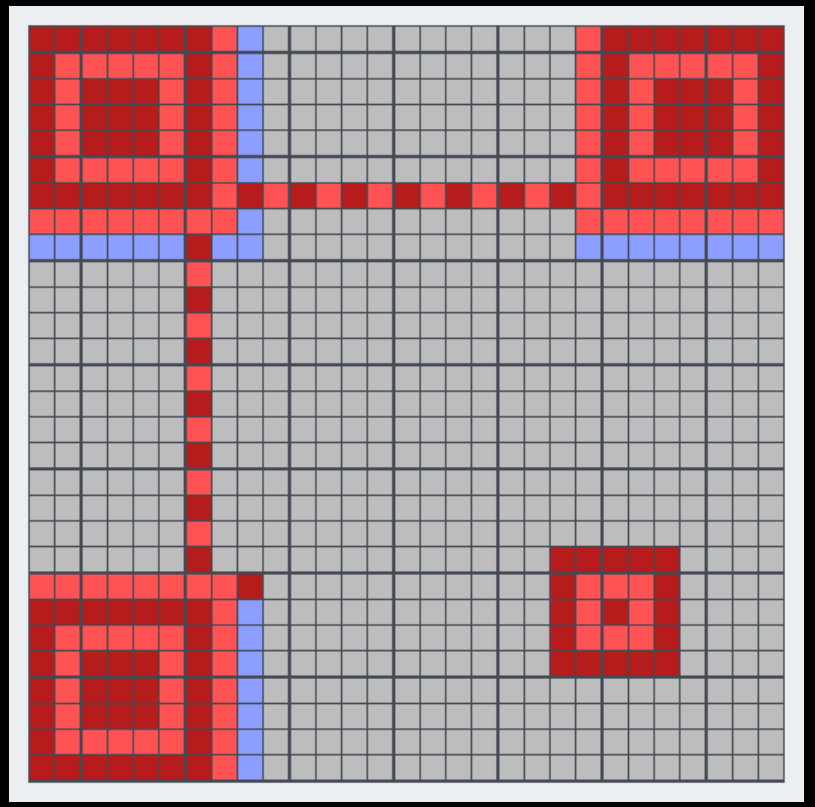
CTFMisc - broken_qrcode

被污染的二维码是否可以复原?



CTFMisc - broken_qrcode

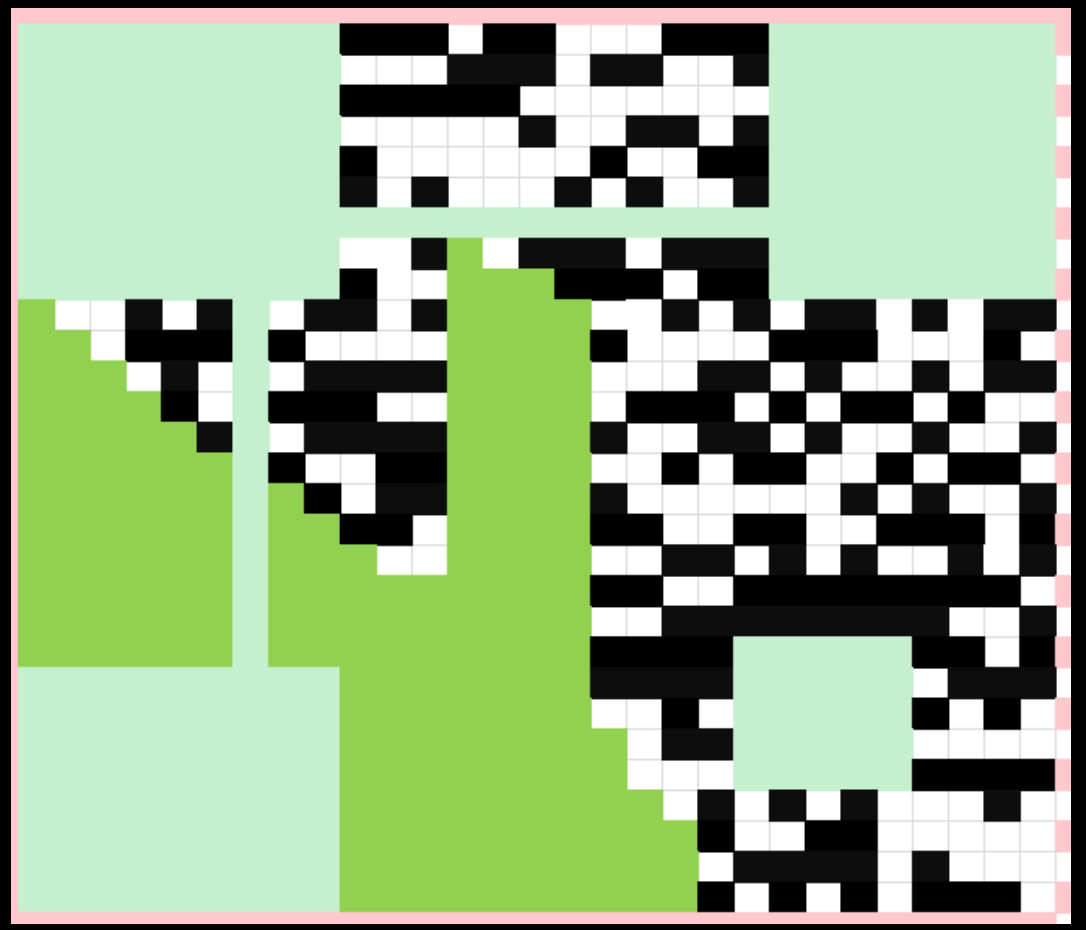
- QRCode Toolbox: https://merricx.github.io/qrazybox/





CTFMisc - broken_qrcode





其他二维码……





CTFMisc - Tricks

- file：根据文件头判断文件类型
- strings：打印文件中可打印的字符，搭配 grep 使用查找 flag
  - strings a.bin | grep –i flag
  - -o：输出偏移
- binwalk：根据文件头去识别一个文件中夹杂的其他文件
  - -e：自动化提取
- Foremost：同 binwalk
- 010Editor：文件 Hex 查看工具

CTFMisc - Tricks

- ASCII 编码：
  - 0-9, 48-57, **0011**0000-**0011**1001
  - A-Z, 65-90, **010**00001-**010**11010
  - a-z, 97-122, **011**00001-**011**11010
- Base X 编码：
  - Base 32
    - A-Z, 2-7, =（**大小写不敏感**）
  - Base 64
    - A-Z, a-z, 0-9, +, /
  - Base 58
    - 不使用数字"0"，字母大写"O"，字母大写"I"，和字母小写"l"，以及"+"和"/"符号
  - Base 85,91,92...
    - 假如 Base X 不行的话，也许可以试试看 Rot

CTFMisc

http://ctf.yasar.li:65199/ezDNS.zip

ezDNS

Just a pcap, right?

CTFMisc - Network Traffic Analysis

- 流量包分析:
  - Wireshark
  - scapy
- 隐蔽信道通信:
  - DNS 信道通信
  - DHCP 信道通信
  - ICMP 信道通信
  - ……

CTFMisc - ezDNS

- DNS 隐蔽信道

732	119.30…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0x7eac A YYQr4IjlKJ8UfRzQgZEy.wchhlbt.cn
733	119.42…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0x7eac A YYQr4IjlKJ8UfRzQgZEy.wchhlbt
734	120.42…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xc890 A UhP9b2BeaKxeORwpUnpj.wchhlbt.cn
735	120.47…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0xc890 A UhP9b2BeaKxeORwpUnpj.wchhlbt
736	121.48…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xb198 A U4ccL/HQkcHmpM/JJPgs.wchhlbt.cn
737	121.53…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0xb198 A U4ccL/HQkcHmpM/JJPgs.wchhlbt
738	122.53…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xad82 A qogXa3Rql6iTdwExQTvb.wchhlbt.cn
739	122.58…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0xad82 A qogXa3Rql6iTdwExQTvb.wchhlbt
740	123.59…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xdba5 A Dp11Z4tnb32a7RgTDq4f.wchhlbt.cn
741	123.68…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0xdba5 A Dp11Z4tnb32a7RgTDq4f.wchhlbt
742	124.69…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xb54a A rIL3+hzvUTXwpW3wpe94.wchhlbt.cn
743	124.78…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0xb54a A rIL3+hzvUTXwpW3wpe94.wchhlbt
744	125.78…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0x52df A Tlx1cuZoiAfjqku5MVpv.wchhlbt.cn
745	125.83…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0x52df A Tlx1cuZoiAfjqku5MVpv.wchhlbt
746	126.84…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0x5986 A +NkuX5tjZznjwSchIcb3.wchhlbt.cn
747	127.01…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0x5986 A +NkuX5tjZznjwSchIcb3.wchhlbt

913	167.48…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xd80b A h7J4dw2AYw8o8WoC+6nn.wchhlbt.cn
917	169.59…	192.168.3.134	8.8.8.8	DNS	91 Standard query 0xd80b A h7J4dw2AYw8o8WoC+6nn.wchhlbt.cn
918	169.66…	8.8.8.8	192.168.3.134	DNS	115 Standard query response 0xd80b A h7J4dw2AYw8o8WoC+6nn.wchhlb

CTFMisc

Game Cheating

CTFMisc

$ nc ctf.yasar.li 65102
web > http://ctf.yasar.li:65199/wnc/65102
http://ctf.yasar.li:65199/wordle.zip

wordle

Wordle is the BEST

https://jonathanolson.net/wordle-solver/

CTFMisc - wordle

$ nc ctf.yasar.li 65102

如何写代码进行大量交互?

```
from pwn import *
context(log_level='info', os='linux')
r = remote('ctf.yasar.li', 65102)

r.sendlineafter(b'>', b'3')
r.sendlineafter(b'>', img_b64)
r.sendlineafter(b'>', b'4')

r.interactive()
```

CTFMisc - wordle

$ nc ctf.yasar.li 65102

```python
def get_challenge():
    # id = random.getrandbits(32)
    # answer = valid_words[id % len(valid_words)]
    # return hex(id)[2:].zfill(8), answer

    # To prevent the disclosure of answer
    id = random.randrange(len(valid_words) * (2 ** 20))
    answer = valid_words[id % len(valid_words)]
    id = (id // len(valid_words)) ^ (id % len(valid_words))
    return hex(id)[2:].zfill(5), answer
```

CTFMisc - wordle

$ nc ctf.yasar.li 65102

- randcrack: https://github.com/tna0y/Python-random-module-cracker
  - 通过读取前 624 次 random.getrandbits(32) 的结果来预测下一次 random.getrandbits(32) 的结果

```
_randbelow = _randbelow_with_getrandbits

def _randbelow_with_getrandbits(self, n):
    "Return a random int in the range [0,n).  Raises ValueError if n==0."

    getrandbits = self.getrandbits
    k = n.bit_length()  # don't use (n-1) here because n can be 1
    r = getrandbits(k)          # 0 <= r < 2**k
    while r >= n:
        r = getrandbits(k)
    return r
```

CTFMisc

多积累各种各样的工具
多观察数据思考其规律

END

Yasar、Nano

2024-07-01